PERFIL PROFESIONAL

Declaración profesional

Soy Licenciado en Criminalística y completé el Certificado Profesional de Ciberseguridad de Google, orientando actualmente mi desarrollo profesional hacia el área de ciberseguridad. Si bien no ejercí profesionalmente en Criminalística, mi formación universitaria me permitió desarrollar habilidades transferibles como el pensamiento analítico, la observación, la atención al detalle, el análisis basado en evidencias y el seguimiento de procedimientos.

A través de mi formación en ciberseguridad adquirí conocimientos y práctica en seguridad de redes, análisis de tráfico, detección y respuesta a incidentes, gestión de riesgos, Linux, SQL y Python, además de fundamentos relacionados con herramientas SIEM e IDS. Tengo especial interés en comenzar mi carrera en áreas como Security Operations Center (SOC), análisis de ciberseguridad y seguridad de redes.

Me caracterizo por ser responsable, autodidacta y comprometido con el aprendizaje continuo. Busco mi primera oportunidad profesional en ciberseguridad, donde pueda aplicar y seguir desarrollando mis conocimientos, trabajar de manera metódica frente a incidentes y contribuir a la protección de sistemas, datos y activos digitales de una organización.

PROYECTO 1

DETECCIÓN, TRIAGE Y ESCALAMIENTO DE POSIBLE COMPROMISO DE CUENTA

- **Rol Simulado:** SOC Analyst L1
- **Organización Simulada:** Orion Financial Group (Sector Financiero)
- **Herramientas y Conceptos Aplicados:** SIEM Triage, Correlation Analysis, NIST Incident Response Lifecycle, 5 W Framework, Evidence-Based Analysis, Technical & Stakeholder Communication, Security Playbooks.

Resumen Ejecutivo (Executive Summary)

Durante el turno de operaciones, el sistema SIEM generó una alerta crítica por múltiples intentos fallidos de autenticación seguidos de un inicio de sesión exitoso desde una dirección IP no asociada históricamente al usuario cfernandez. Como Analista SOC L1, realicé el triage inicial, la correlación de eventos, la validación de la actividad posterior (descarga de archivos y acceso a recursos) y estructuré el escalamiento técnico hacia el nivel L2, aplicando principios de protección de datos y comunicación diferenciada (técnica vs. ejecutiva).

Detección y Línea Temporal del Incidente (Timeline Analysis)

- **Alerta SIEM (10:12):** Múltiples fallos de autenticación seguidos de éxito (cfernandez / IP: 185.220.101.44).

- **Secuencia reconstruida:**

- 09:54 - 09:58 ➡ 5 intentos fallidos de inicio de sesión.
- 09:59 ➡ Autenticación **exitosa** desde la misma IP sospechosa.
- 10:03 - 10:06 ➡ Acceso al almacenamiento corporativo y descarga de clientes_Q3.xlsx y contratos_clientes.zip (archivos dentro de los permisos legítimos del usuario).
- 10:10 ➡ Intento de acceso al recurso restringido Finance-Shared (**Acceso rechazado** por falta de privilegios).

Análisis Metodológico (Enfoque de las 5 W)

- **Who (¿Quién?):** Cuenta corporativa afectada: cfernandez (Área Comercial). La identidad real del operador de la sesión no pudo validarse inicialmente.
- **What (¿Qué ocurrió?):** Fuerza bruta o uso de credenciales comprometidas seguido de acceso a recursos de red y exfiltración potencial de dos documentos.
- **When (¿Cuándo?):** Mañana de un día laborable (09:54 - 10:12), lo que obligó a profundizar la investigación más allá de la simple hora del evento.
- **Where (¿Dónde?):** Involucró el sistema de autenticación, almacenamiento compartido interno y pasarela de red.
- **Why (¿Por qué?):** Indicadores consistentes con el uso no autorizado de credenciales, buscando acceso a información sensible de clientes.

Triage Inicial: Hechos Confirmados vs. Incertidumbres

- **Hechos Confirmados:**
  - Secuencia de autenticación fallida + exitosa desde la IP 185.220.101.44.
  - Descarga legítima por permisos de la cuenta de dos archivos comerciales.
  - Intento bloqueado al recurso de finanzas.
- **Aspectos No Determinados (Pendientes de L2):**
  - Vector inicial de robo de credenciales (phishing, infostealer, etc.).
  - Presencia de malware en el endpoint (no concluyente).
  - Si los archivos descargados fueron exfiltrados fuera de la red corporativa.

Escalamiento y Comunicaciones Profesionales

- **A. Comunicación Técnica (Para SOC L2 / Incident Response):**

"Se escalan eventos de la cuenta cfernandez tras detectar patrón de fuerza bruta exitoso desde IP externa no asociada al historial (185.220.101.44), dispositivo no reconoido y ausencia de MFA. La sesión descargó clientes_Q3.xlsx y contratos_clientes.zip. Intento a Finance-Shared denegado. Se solicita análisis de malware en endpoint y verificación de exfiltración de datos."

- **B. Comunicación No Técnica (Para Stakeholders / Gerencia):**

"Hemos detectado actividad inusual en una cuenta corporativa interna. El acceso no autorizado fue contenido rápidamente. Los intrusos accedieron a documentación comercial estándar para la cual la cuenta tenía permisos, pero los sistemas de seguridad bloquearon intentos posteriores en áreas restringidas. No hay evidencia confirmada de salida de información fuera de la empresa y el caso está siendo investigado activamente."

Acciones de Contención Propuestas

- Deshabilitación temporal de la cuenta y revocación de tokens de sesión activos.
- Restablecimiento seguro de credenciales y aplicación obligatoria de MFA.
- Preservación de logs del SIEM y telemetría de EDR para la auditoría posterior.

PROYECTO 2

AUDITORÍA INTERNA DE SEGURIDAD Y CUMPLIMIENTO (BOTIUM TOYS)

- **Proyecto Práctico** basado en una actividad del Certificado de Ciberseguridad de Google, desarrollado sobre el caso simulado de Botium Toys.

- **Rol Simulado:** IT Security Auditor / Compliance Analyst
- **Organización Simulada:** Botium Toys (Comercio minorista y en línea)
- **Herramientas y Conceptos Aplicados:** NIST Cybersecurity Framework (CSF), PCI DSS, GDPR, Security Controls Assessment, Least Privilege, Separation of Duties, Risk Mitigation.

Resumen Ejecutivo

Se realizó una auditoría interna de seguridad sobre la empresa ficticia Botium Toys para evaluar su postura frente a estándares de la industria y normativas internacionales. El análisis determinó un nivel de riesgo alto (8/10), impulsado por la ausencia de cifrado en datos de tarjetas de crédito, falta de controles de acceso basados en privilegios mínimos y deficiencias en el cumplimiento de normativas como PCI DSS y GDPR.

Alcance y Metodología

- **Alcance:** El programa de seguridad global de la compañía, incluyendo red interna, dispositivos de empleados, servicios de comercio electrónico y almacenamiento de datos.
- **Metodología:** Evaluación basada en el marco **NIST CSF** y revisión de cumplimiento normativo (PCI DSS, GDPR, SOC 1 y SOC 2).

Hallazgos Clave y Brechas Identificadas

- **Control de Accesos:** Ausencia del principio de *Mínimo Privilegio* y *Separación de Funciones*, lo que otorga a los usuarios permisos superiores a los necesarios.

- **Protección de Datos:** Falta de cifrado para información de tarjetas de pago, lo que representa una brecha crítica frente a los requisitos de PCI DSS, y deficiencias específicas en el cumplimiento del GDPR, particularmente en la clasificación e inventario de datos personales.
- **Respuesta y Recuperación:** Inexistencia de un Plan de Recuperación ante Desastres (DRP) y ausencia de copias de seguridad automatizadas.
- **Detección:** Falta de un Sistema de Detección de Intrusos (IDS) para monitorear actividades anómalas en la red.

Recomendaciones Prioritarias

- Implementar estrictamente el **Principio de Mínimo Privilegio** y controles de separación de funciones.
- Desplegar cifrado robusto para los datos de tarjetas de crédito y transacciones de clientes en tránsito y reposo.
- Instalar un **IDS** y establecer copias de seguridad periódicas junto con un Plan de Recuperación ante Desastres documentado.

PROYECTO 3

EVALUACIÓN DE RIESGOS Y CONTROLES DE INFRAESTRUCTURA (NOVATECH SOLUTIONS)

- **Rol Simulado:** Junior Risk Analyst / Information Security Evaluator.
- **Organización Simulada:** NovaTech Solutions (PyME híbrida de 35 empleados).
- **Herramientas y Conceptos Aplicados:** NIST SP 800-30 Rev. 1, Risk Assessment, Threat Identification, Vulnerability Prioritization, Asset Management, CIA Triad y Security Controls.

Resumen Ejecutivo

Se realizó una evaluación cualitativa de riesgos sobre la infraestructura tecnológica de la empresa ficticia NovaTech Solutions, utilizando como referencia la metodología NIST SP 800-30 Rev. 1. El análisis permitió identificar vulnerabilidades relacionadas con el trabajo híbrido, la ausencia de cifrado en equipos corporativos, los permisos excesivos, la falta de autenticación multifactor (MFA) y las deficiencias en los procesos de respaldo y recuperación. Como resultado, se elaboró una matriz de priorización de riesgos y un conjunto de recomendaciones técnicas orientadas a fortalecer la seguridad de la infraestructura y proteger la confidencialidad, integridad y disponibilidad de la información.

Alcance y Metodología

- **Alcance:** Activos tecnológicos, estaciones de trabajo Windows, notebooks corporativas, red Wi-Fi, servidor interno de archivos, servicios de almacenamiento en la nube, cuentas de usuario y mecanismos de acceso remoto.
- **Metodología:** Evaluación cualitativa de riesgos basada en NIST SP 800-30 Rev. 1, mediante la estimación de la probabilidad y el impacto de las amenazas sobre la Tríada CIA (Confidencialidad, Integridad y Disponibilidad).

Principales Riesgos Identificados

1. **Equipos Corporativos sin Cifrado (Riesgo Alto):** Notebooks corporativas sin cifrado de disco completo, vulnerables a la exposición de información ante pérdidas o robos físicos.
2. **Permisos Excesivos (Riesgo Alto):** Asignación de permisos superiores a los necesarios para las funciones de los empleados, incumpliendo el principio de mínimo privilegio.
3. **Acceso Remoto sin VPN (Riesgo Alto):** Acceso de empleados remotos a recursos corporativos sin mecanismos de conexión protegidos mediante una VPN corporativa.
4. **Ausencia de Autenticación Multifactor (MFA) (Riesgo Medio):** Falta de una segunda capa de autenticación que reduzca el riesgo de acceso no autorizado ante el compromiso de credenciales.
5. **Gestión Deficiente de Backups y Recuperación (Riesgo Alto):** Copias de seguridad manuales sin periodicidad definida ni pruebas formales de restauración, junto con la ausencia de un Plan de Recuperación ante Desastres (DRP).
6. **Falta de Inventario y Concientización (Riesgo Alto):** Inventario de activos tecnológicos desactualizado y ausencia de programas periódicos de capacitación en seguridad para los empleados.
7. **Proceso de Offboarding No Formalizado (Riesgo Medio):** Existencia de un procedimiento operativo de baja de accesos que no se encuentra formalmente documentado.

Estrategia de Mitigación y Remediación

- Implementar cifrado de disco completo en todas las notebooks y equipos corporativos.
- Revisar y ajustar los permisos de usuario conforme al principio de mínimo privilegio y las responsabilidades de cada puesto.
- Desplegar MFA de forma prioritaria en accesos remotos y cuentas con privilegios elevados.
- Establecer mecanismos seguros de acceso remoto mediante una VPN corporativa.
- Automatizar las copias de seguridad, establecer una periodicidad definida, realizar pruebas de restauración y documentar un Plan de Recuperación ante Desastres.
- Mantener un inventario centralizado y actualizado de los activos tecnológicos.
- Desarrollar programas periódicos de capacitación y concientización en seguridad.

- Formalizar los procedimientos de altas y bajas de personal, incluyendo la revocación oportuna de accesos.

PROYECTO 4

ANÁLISIS DE TRÁFICO DE RED CON WIRESHARK

Rol Simulado: Network Security Analyst / Packet Inspector

Entorno: Laboratorio virtualizado y aislado en Oracle VirtualBox, con Kali Linux y Metasploitable 2 conectados mediante una red Host-Only.

- **Herramientas:** Wireshark, **`ping`**, **`curl`**, cliente FTP y **`nslookup`**.

Resumen ejecutivo

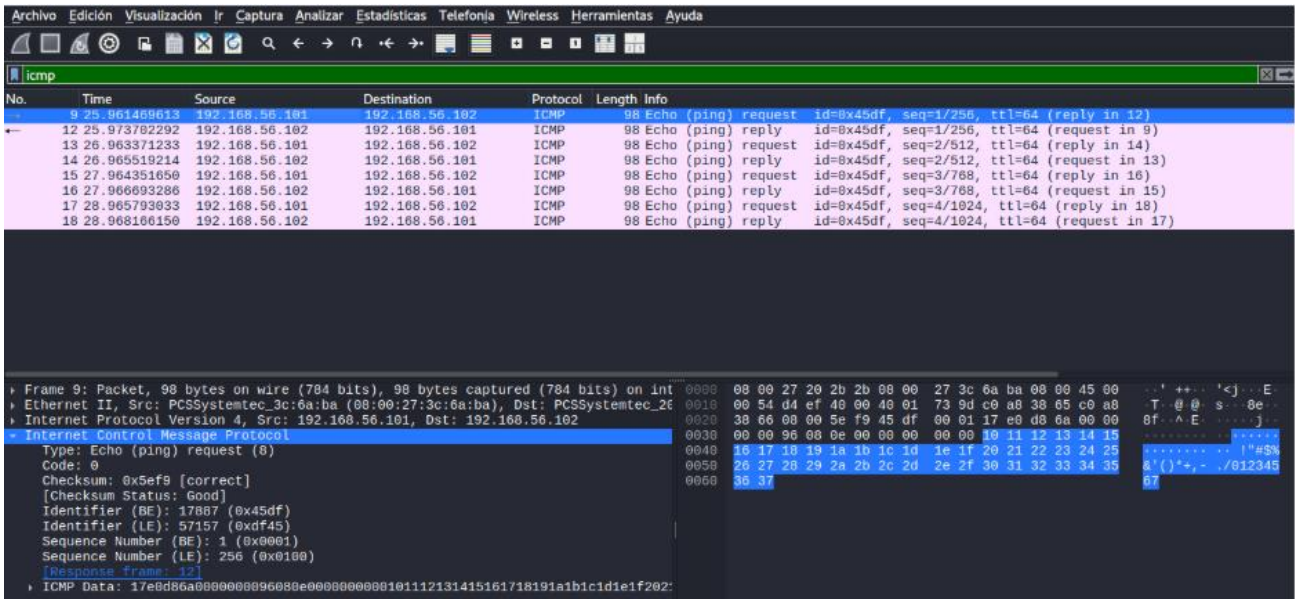
Se realizó un análisis de tráfico de red con Wireshark en un laboratorio virtualizado mediante **`Oracle VirtualBox`**, utilizando una red **`Host-Only`** para estudiar las comunicaciones entre Kali Linux (**`192.168.56.101`**) y Metasploitable 2 (**`192.168.56.102`**).

El objetivo fue identificar protocolos, observar intercambios de paquetes e interpretar las respuestas obtenidas durante distintas pruebas de conectividad y servicios de red.

Las pruebas confirmaron conectividad **`ICMP`**, una respuesta **`HTTP 200 OK`**, la identificación de un servicio FTP y diferentes resultados en consultas DNS. No se obtuvo evidencia suficiente para confirmar robo de credenciales, explotación de vulnerabilidades o actividad maliciosa.

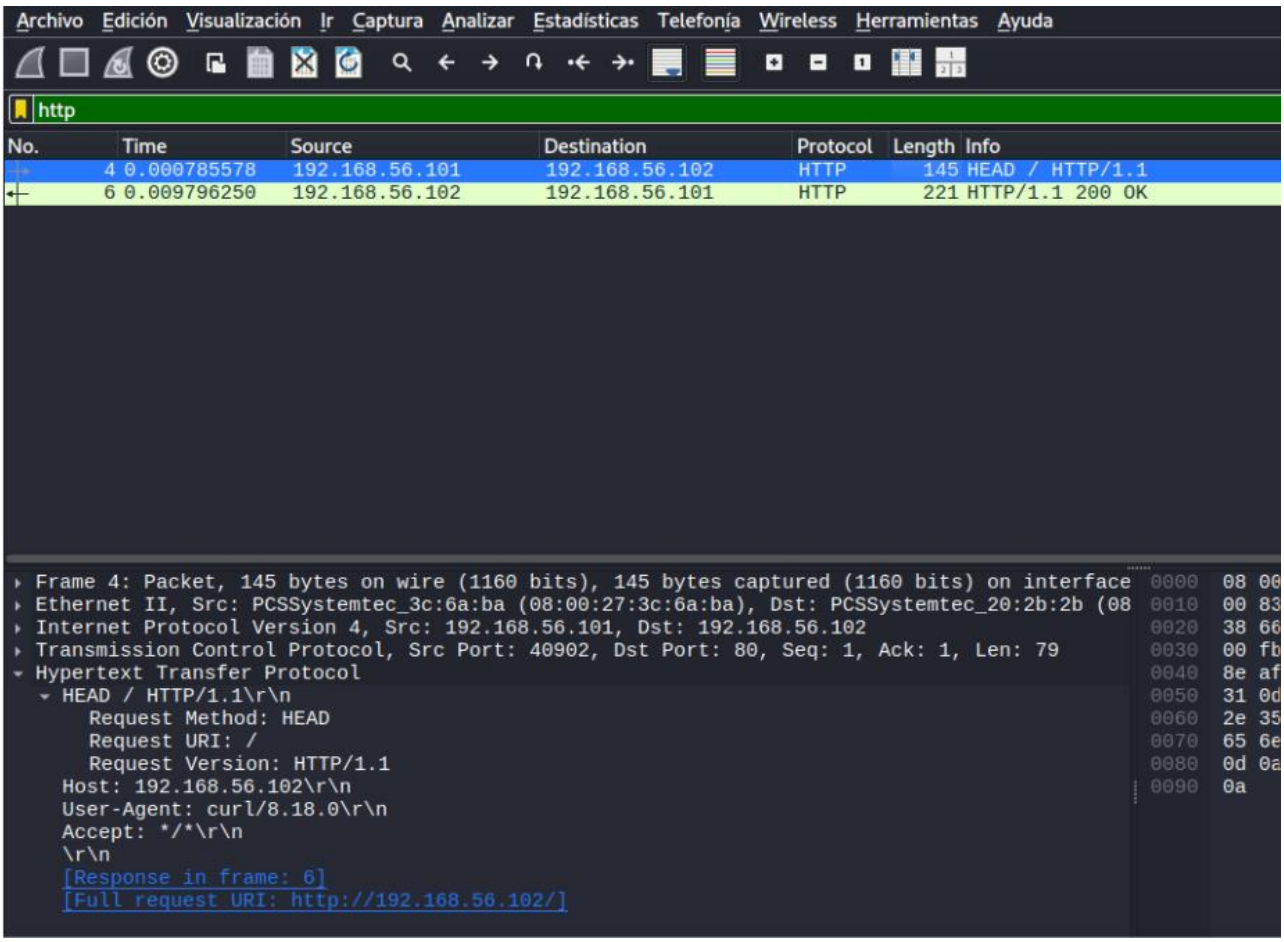
Metodología y hallazgos

- **ICMP:** Se comprobó la conectividad entre ambos equipos mediante **`ping`**, observando solicitudes y respuestas **`Echo Request/Echo Reply`**.



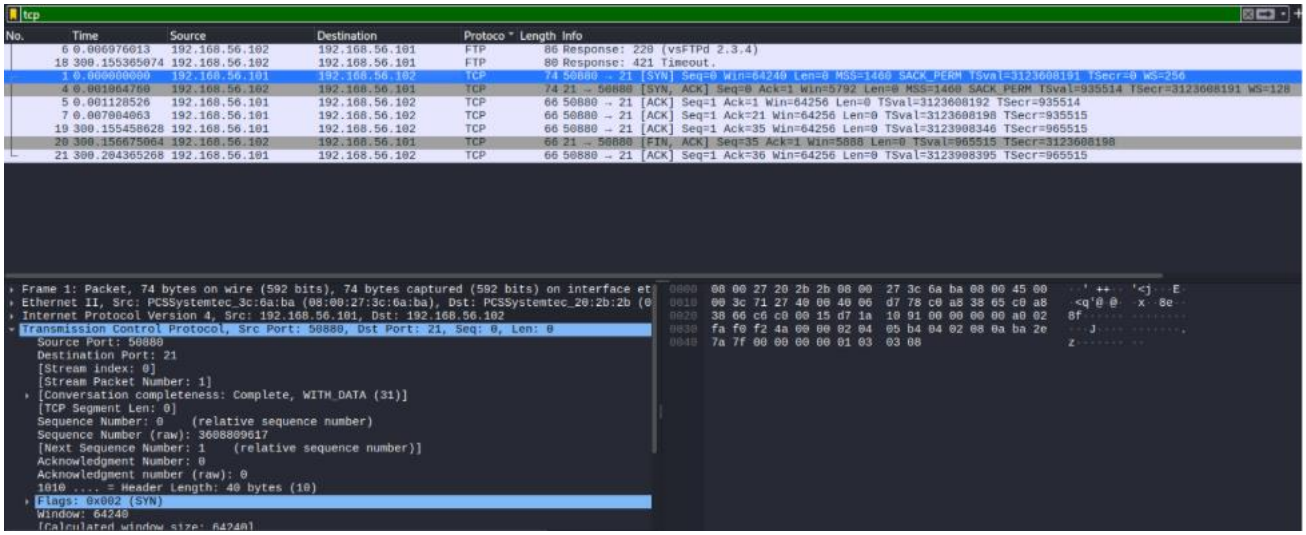
Captura 1 - Verificación de conectividad entre equipos.

- **HTTP:** La solicitud realizada mediante **`curl -I`** recibió una respuesta **`HTTP/1.1 200 OK`**. Wireshark permitió observar la solicitud **HEAD** y las cabeceras HTTP en texto legible. En esta captura no se observó transmisión de contraseñas.



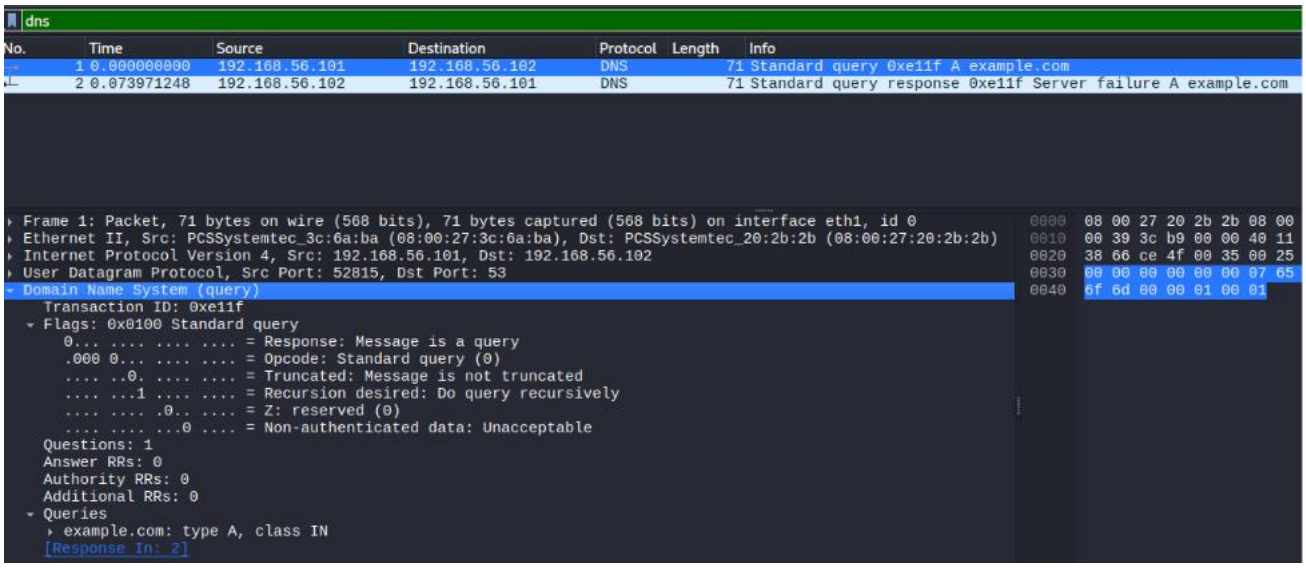
Captura 2 - Solicitud y respuesta HTTP

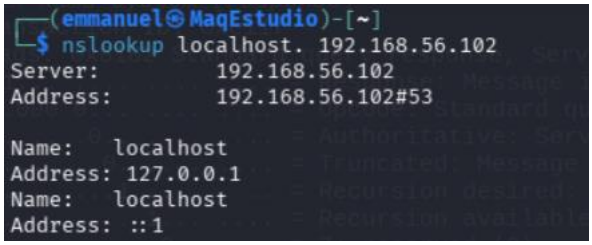
- **FTP/TCP:** Se identificó el servicio FTP mediante el banner **`220 (vsFTPd 2.3.4)`** y se observó el establecimiento de la conexión TCP mediante el intercambio **`SYN, SYN/ACK y ACK`**. Posteriormente, el servidor respondió **`421 Timeout.`**. En esta sesión no se evidenciaron una autenticación completada ni una transferencia de archivos.



Captura 3 - Establecimiento de la conexión TCP y respuestas FTP

- **DNS:** La consulta DNS para **`example.com`** recibió una respuesta **`SERVFAIL`** del servidor **`192.168.56.102`**, sin obtener una dirección IP para el dominio. En una comprobación independiente, **`localhost`** se resolvió correctamente a **`127.0.0.1`** y **`::1`**. Los resultados evidencian un fallo en la resolución del dominio externo probado, mientras que la resolución del nombre local funcionó correctamente.





Captura 4 y 5 - Respuesta DNS SERVFAIL y resolución de localhost.

- **Conectividad externa y diagnóstico DNS:** El intento de alcanzar **`1.1.1.1`** devolvió **`Network is unreachable`**. Durante la investigación también se identificó la ausencia de una ruta predeterminada visible en el entorno. Estas condiciones podían contribuir al fallo de resolución DNS de **`example.com`**, aunque no se confirmó que fueran su causa única.

- **Comprobación de puertos:** Se realizó una comprobación específica con **`Nmap`** sobre el puerto UDP 53 de Metasploitable 2, que fue identificado como abierto. No se dispone de evidencia de un escaneo general de puertos ni de anomalías TCP confirmadas en las capturas analizadas.

Recomendaciones

- Utilizar HTTPS en lugar de HTTP y preferir SFTP o FTPS frente a FTP tradicional para proteger las comunicaciones.
- Revisar la configuración DNS, las rutas de red y la conectividad externa cuando se investiguen fallos de resolución.
- Conservar las capturas originales en formato .**`pcapng`** y verificar que respalden los hallazgos documentados.
- Mantener Metasploitable 2 en una red aislada, sin modo puente ni exposición a redes públicas.

Limitaciones

El análisis se limita a los paquetes y resultados documentados durante las pruebas. La reproducibilidad depende de conservar y verificar las capturas .**`pcapng`** originales.

No se confirmó robo de credenciales, explotación de vulnerabilidades ni comunicación de comando y control (C2). Los resultados DNS tampoco permitieron establecer una causa definitiva del fallo de resolución externa.

Conclusión

El proyecto permitió practicar la captura y el análisis de paquetes, la identificación de protocolos y la interpretación de respuestas HTTP, FTP, TCP y DNS. La principal conclusión es que los hallazgos de seguridad deben sustentarse en evidencia verificable, diferenciando los resultados confirmados de las hipótesis pendientes.

PROYECTO 5

AUTOMATIZACIÓN DE TAREAS DE CIBERSEGURIDAD CON PYTHON

- **Rol Simulado:** Junior Security Automation Developer
- **Herramientas y Conceptos Aplicados:** Python (Algoritmos, Bucles for/while, Funciones, Condicionales, Manejo de Archivos), Scripting para SOC, Gestión de Listas de Bloqueo (Blocklists).

Resumen Ejecutivo

Se desarrolló un script en **Python** para automatizar la actualización y el filtrado de listas de direcciones IP bloqueadas (*block lists*) dentro de la infraestructura corporativa. La solución reduce el tiempo de respuesta operativo al procesar de forma automática archivos de registro (*log files*), eliminando IPs autorizadas y optimizando la gestión de Indicadores de Compromiso (IOCs).

Alcance y Metodología

- **Alcance:** Procesamiento automatizado de listas de control de acceso y archivos de texto plano con registros de conexión.
- **Metodología:** Uso de lógica de programación (apertura de archivos, lectura línea por línea, estructuras condicionales y manipulación de listas) para validar entradas de red contra políticas de seguridad predefinidas.

Componentes Técnicos Desarrollados

- **Lectura y Manipulación de Archivos:** Implementación de funciones para abrir archivos de texto, extraer direcciones IP y convertirlas en estructuras de datos iterables.
- **Algoritmo de Filtrado y Actualización:** Lógica para recorrer una lista de IPs restringidas y remover (*remove*) aquellas que ya no deben estar bloqueadas o que forman parte de excepciones aprobadas.
- **Automatización del Flujo de Trabajo:** Reducción drástica del esfuerzo manual del analista al procesar cientos de registros en segundos.

Beneficios Operativos

- Optimización del tiempo de análisis en el SOC mediante la automatización de tareas repetitivas de verificación de IOCs.
- Base sólida para escalar hacia integraciones con APIs de seguridad y plataformas de orquestación (SOAR).

PROYECTO 6

AUDITORÍA DE REGISTROS Y ACCESOS MEDIANTE CONSULTAS SQL

- **Rol Simulado:** Security Data Analyst / Database Auditor
- **Herramientas y Conceptos Aplicados:** SQL (Consultas relacionales, Cláusulas SELECT, WHERE, JOIN, Filtrado de logs, Análisis de autenticación).

Resumen Ejecutivo

Se diseñaron y ejecutaron consultas avanzadas en **SQL** sobre bases de datos de control de acceso y autenticación corporativa. El objetivo principal fue auditar los registros de actividad (*logs*), identificar patrones de intentos fallidos de inicio de sesión y analizar los permisos asignados a las cuentas de usuario para prevenir escalamientos de privilegios no autorizados.

Alcance y Metodología

- **Alcance:** Tablas relacionales de registros de eventos de login, perfiles de usuario y asignación de roles de acceso.
- **Metodología:** Aplicación de comandos de consulta estructurados (SELECT, filtrado condicional por fechas y horas, uso de operadores lógicos y uniones de tablas) para extraer anomalías de seguridad directamente de las bases de datos.

Hallazgos y Consultas Clave

- **Detección de Intentos Fallidos de Autenticación:**
  - *Descripción:* Creación de consultas orientadas a aislar registros con múltiples fallos de contraseña concentrados en franjas horarias no laborales, facilitando la detección temprana de ataques de fuerza bruta.
- **Auditoría de Privilegios de Usuario:**
  - *Descripción:* Uso de cruces de tablas (*JOINs*) para mapear qué usuarios poseían roles administrativos activos frente a los que requerían privilegios estándar (aplicación del principio de menor privilegio).
- **Análisis de Conexiones por Dirección IP:**
  - *Descripción:* Filtrado de tablas de transacciones para rastrear el origen geográfico o de red de las sesiones iniciadas en los sistemas críticos.

Valor para la Organización

- Capacidad técnica comprobada para extraer y analizar grandes volúmenes de datos de seguridad directamente desde bases de datos corporativas.
- Mejora en la trazabilidad de incidentes a través de consultas rápidas y precisas sobre los registros históricos de auditoría.